

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 05

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM2-001)

Which outcome BEST indicates that information security governance is aligned with enterprise governance?

- A. Security teams independently select controls for every business unit.
- B. Technology standards remain unchanged despite shifts in business strategy.
- C. Security decisions support enterprise objectives within approved risk boundaries.
- D. The governing body delegates all information risk decisions to technical personnel.

Question 2 (CISM2-002)

Scenario: A global consulting firm grants regional leaders significant decision authority. A new security policy requires headquarters to approve all local risk treatments, and regional leaders routinely delay or bypass approvals.

What should the information security manager do FIRST?

- A. Withdraw all regional authority until policy compliance improves.
- B. Define delegated decision thresholds, accountability, and escalation rules consistent with the operating model.
- C. Ask internal audit to approve routine regional risk treatments.
- D. Deploy additional monitoring tools before revising the governance process.

Question 3 (CISM2-003)

Scenario: A payment services company receives conflicting interpretations of a new contractual security requirement from legal counsel, operations, and a major customer. Implementation must begin within two months.

What is the MOST appropriate governance response?

- A. Obtain an authoritative interpretation, assess its impact, and assign accountable owners for required actions.
- B. Adopt the customer's interpretation without considering enterprise impact.
- C. Postpone all action until an external audit determines the answer.
- D. Let each department implement its preferred interpretation.

Question 4 (CISM2-004)

Who is ultimately accountable for ensuring that information security governance supports enterprise objectives?

- A. The external security assessor
- B. The security technology vendor
- C. The network operations team
- D. The governing body and executive leadership

Question 5 (CISM2-005)

Scenario: Because of staffing shortages, the director responsible for operating privileged-access controls also approves exceptions and leads the independent assessment of those controls.

What is the GREATEST governance concern?

- A. The control may require additional automation.
- B. Exception records may contain too much operational detail.
- C. Privileged access should be governed only by the technology department.
- D. Incompatible operational, approval, and assurance responsibilities undermine independent oversight.

Question 6 (CISM2-006)

Scenario: A municipal services organization is designing a digital citizen-service capability. Business processes and information exchanges are being defined before applications and technologies are selected.

How should the information security manager contribute at this stage?

- A. Wait until products are selected and then perform configuration testing.
- B. Identify information risks and security requirements within the capability and architecture decisions.
- C. Assume ownership of the entire citizen-service architecture.
- D. Require every existing security control to be replicated regardless of the new service design.

Question 7 (CISM2-007)

Why should information security governance explicitly define decision rights?

- A. To allow control operators to accept any residual business risk
- B. To eliminate the need for collaboration among business functions
- C. To clarify who may make decisions, who is accountable, and when escalation is required
- D. To ensure every security decision is made by the same committee

Question 8 (CISM2-008)

Scenario: An enterprise is acquiring a smaller company whose security practices fall below enterprise requirements. Immediate replacement of all systems would disrupt a strategically important product launch.

Which recommendation BEST balances governance and business needs?

- A. Permit indefinite noncompliance because the acquisition has strategic value.
- B. Document the exposure, assign risk ownership, approve time-bound treatment, and monitor integration milestones.
- C. Transfer accountability for inherited risk to the acquired company's technical staff.
- D. Replace every inherited system before completing the acquisition.

Question 9 (CISM2-009)

Scenario: Customer data deletion requests pass through privacy, customer service, application support, and records management. Requests frequently remain incomplete because each group assumes another group owns the result.

What should the information security manager recommend?

- A. Allow each function to establish an independent completion target.
- B. Assign the entire process to the application support team.
- C. Ask internal audit to perform the deletion activities.
- D. Designate an accountable process owner and document responsibilities, handoffs, and escalation criteria.

Question 10 (CISM2-010)

Scenario: A business unit proposes a customer analytics platform that conflicts with an approved data architecture principle. The unit claims the exception is necessary to meet a time-sensitive market opportunity.

What should the information security manager do NEXT?

- A. Limit the review to the platform's technical security features.
- B. Reject the platform solely because it differs from the approved architecture.
- C. Approve the exception because the business unit owns the project budget.
- D. Assess security and business impacts, then submit the exception to architecture governance.

Question 11 (CISM2-011)

Which set of factors is MOST relevant when establishing an information security strategy?

- A. Enterprise objectives, risk appetite, obligations, threat conditions, and organizational capabilities
- B. Only current security technologies and vendor release schedules
- C. Only previously reported incidents and audit findings
- D. Individual preferences of security operations personnel

Question 12 (CISM2-012)

Scenario: A pharmaceutical distributor defines a desired capability to identify critical supplier disruptions within four hours. The current process relies on quarterly questionnaires and has no event-notification mechanism.

What does the gap analysis MOST directly establish?

- A. That quarterly questionnaires should be discontinued immediately
- B. That every supplier requires identical technical monitoring
- C. That current detection practices cannot achieve the required notification outcome
- D. That the desired capability is unnecessary unless a disruption occurs

Question 13 (CISM2-013)

Scenario: A digital marketplace has approved a very low tolerance for prolonged payment outages. Its proposed security strategy contains only general availability statements with no recovery target or accountable initiative.

What should the information security manager recommend?

- A. Use the number of installed security products as the resilience target.
- B. Remove availability from the strategy because operations owns service uptime.
- C. Define measurable resilience objectives and initiatives consistent with the approved outage tolerance.
- D. Wait for a major outage before establishing a measurable objective.

Question 14 (CISM2-014)

Scenario: A multinational food producer wants to improve security governance and operational control consistency. Leaders disagree because one proposed framework emphasizes governance while another offers detailed control practices.

What is the BEST recommendation?

- A. Select whichever framework has the largest number of requirements.
- B. Define organizational needs, map complementary practices, and tailor an integrated approach.
- C. Adopt both frameworks in full without resolving overlap.
- D. Avoid frameworks and allow each site to create an unrelated model.

Question 15 (CISM2-015)

Scenario: Halfway through a three-year roadmap, a construction company faces a major reduction in capital spending. The current portfolio includes regulatory commitments, a critical identity dependency, several convenience enhancements, and duplicated regional tools.

How should the information security manager recommend reducing the portfolio?

- A. Reduce every initiative's budget by the same percentage.
- B. Cancel all multiyear initiatives and spend only on current incidents.
- C. Protect initiatives sponsored by the most senior executives regardless of value.
- D. Preserve mandatory and high-value dependencies, consolidate duplication, and defer lower-priority enhancements.

Question 16 (CISM2-016)

Scenario: A chief executive publicly endorsed the security strategy, but business leaders repeatedly refuse to assign staff to approved initiatives. Progress reports contain no named business owners or unresolved decisions.

What is the MOST significant underlying weakness?

- A. Executive endorsement has not been converted into accountable ownership and resource commitments.
- B. The strategy contains too few technology projects.
- C. The organization has not purchased a project management platform.
- D. The security team needs more detailed technical metrics.

Question 17 (CISM2-017)

Scenario: A hospital group's strategy calls for stronger data governance, automated access decisions, and advanced analytics monitoring. Reliable data ownership and classification do not yet exist.

How should the roadmap be sequenced?

- A. Run all initiatives independently without documenting dependencies.
- B. Implement advanced monitoring first because it is the most technically sophisticated initiative.
- C. Establish data ownership and classification before capabilities that depend on trustworthy data context.
- D. Delay data governance until every application has been replaced.

Question 18 (CISM2-018)

Scenario: A consumer finance company seeks to reduce the time that critical access violations remain unresolved. Its dashboard reports only the number of access reviews completed each month.

Which metric would BEST supplement the dashboard?

- A. The percentage of critical violations resolved within the approved time threshold
- B. The total number of accounts reviewed, regardless of risk
- C. The number of pages in the access control standard
- D. The number of meetings attended by the access administration team

Question 19 (CISM2-019)

Scenario: A conglomerate is replacing separate business-unit platforms with common enterprise services. The security roadmap continues to fund separate tools and teams for each retiring platform, while the target architecture requires shared identity, data protection, and monitoring capabilities.

What is the BEST strategic response?

- A. Continue all existing investments until each platform has been retired.
- B. Let each business unit define an independent target security architecture.
- C. Stop every legacy control immediately to accelerate migration.
- D. Realign investments to transition risks and shared target capabilities while maintaining necessary interim protection.

Question 20 (CISM2-020)

Scenario: A research organization has approved a strategy requiring cloud governance and supplier assurance capabilities. Its current team has little experience in either area, and hiring all required specialists would take more than a year.

What should the information security manager do NEXT?

- A. Proceed without addressing the capability gaps because the strategy is already approved.
- B. Develop a workforce plan combining training, targeted hiring, and appropriate external support.
- C. Purchase additional tools and assume they will remove the need for expertise.
- D. Replace the strategic objectives with tasks the existing team can already perform.

Question 21 (CISM2-021)

What is the PRIMARY role of an enterprise information security policy?

- A. To document detailed steps for every recurring security task
- B. To establish management direction, principles, authority, and mandatory expectations
- C. To list all vulnerabilities discovered in enterprise systems
- D. To replace standards, procedures, and supporting guidelines

Question 22 (CISM2-022)

Scenario: An aviation services company can fund either a highly visible security analytics upgrade or a less visible redesign of access governance required for a planned partner ecosystem. Both proposals have positive returns, but the partner launch depends on reliable cross-company access decisions.

Which investment should the information security manager recommend?

- A. The access governance redesign because it addresses a strategic dependency and associated risk.
- B. The analytics upgrade because visible technology creates greater executive confidence.
- C. Whichever proposal was submitted first by its sponsor.
- D. Neither proposal because security investments should not enable business expansion.

Question 23 (CISM2-023)

Scenario: Six months after annual approval of a security strategy, the enterprise announces a major change from direct sales to a franchise model involving hundreds of independent operators.

What should the information security manager do?

- A. Wait for the next annual review to preserve the approved planning cycle.
- B. Require franchises to use every internal control without evaluating feasibility.
- C. Initiate a focused strategy review of changed stakeholders, dependencies, risks, and capabilities.
- D. Transfer ownership of information security strategy to the franchise operators.

Question 24 (CISM2-024)

Scenario: Business units initially supported a data protection initiative but now resist implementation because benefits appear enterprise-wide while costs are charged entirely to individual units.

What is the BEST response from the information security manager?

- A. Escalate every objection as a policy violation without further discussion.
- B. Revisit benefits, cost allocation, accountabilities, and sponsorship with the affected decision-makers.
- C. Require the security department to absorb all costs regardless of ownership.
- D. Remove the initiative from the strategy because stakeholders raised concerns.

Question 25 (CISM2-025)

Scenario: A public transportation agency's desired state includes consistent security risk decisions across all operating divisions. Its proposed roadmap contains separate technology purchases but no common decision process or risk criteria.

Why is the roadmap insufficient?

- A. Technology investments cannot contribute to any strategic objective.
- B. Every security roadmap must contain only policy initiatives.
- C. Its initiatives do not address the governance capability needed to reach the desired state.
- D. The desired state should be defined only after all projects are complete.

Question 26 (CISM2-026)

Scenario: A warehouse operator needs funding to replace an unsupported access management service. Executives agree that replacement is necessary but want to compare implementation approaches and understand operational disruption.

What should the information security manager include in the business case?

- A. Risk exposure, expected outcomes, lifecycle costs, alternatives, dependencies, and transition impacts
- B. A statement that unsupported technology must be replaced at any cost
- C. Only a list of technical weaknesses in the current service
- D. Only the purchase price of the manager's preferred solution

Question 27 (CISM2-027)

Scenario: The digital strategy calls for rapid adoption of external platforms, the architecture roadmap calls for service consolidation, and the security strategy continues to prioritize controls designed for internally hosted systems. Separate committees approve each roadmap without a shared review.

What should the information security manager recommend FIRST?

- A. Convene the authorized stakeholders to reconcile objectives, dependencies, risk boundaries, and investment priorities.
- B. Continue the security roadmap until technical teams report implementation problems.
- C. Allow each committee to optimize its roadmap independently.
- D. Replace the security strategy with the architecture roadmap.

Answer Key

Domain I - Information Security Governance

1 C	2 B	3 A	4 D	5 D
6 B	7 C	8 B	9 D	10 D
11 A	12 C	13 C	14 B	15 D
16 A	17 C	18 A	19 D	20 B
21 B	22 A	23 C	24 B	25 C
26 A	27 A			

Detailed Explanations

Question 1 (CISM2-001)

Correct answer: C - Security decisions support enterprise objectives within approved risk boundaries.

Alignment is demonstrated when security decisions enable enterprise objectives while respecting approved risk boundaries. Independent control selection can create inconsistency, static standards may not support strategic change, and governing bodies retain oversight rather than transferring all information risk decisions to technical teams.

Question 2 (CISM2-002)

Correct answer: B - Define delegated decision thresholds, accountability, and escalation rules consistent with the operating model.

Delegated thresholds and clear escalation preserve the firm's decentralized model while maintaining accountability and enterprise oversight. Removing all authority conflicts with the operating culture, internal audit should not own management decisions, and monitoring tools do not resolve unsuitable decision rights.

Question 3 (CISM2-003)

Correct answer: A - Obtain an authoritative interpretation, assess its impact, and assign accountable owners for required actions.

An authoritative interpretation followed by impact analysis and assigned ownership provides a consistent, accountable response. Department-specific interpretations create fragmentation, automatically accepting the customer's view may misstate the obligation, and waiting for an audit risks missing the implementation deadline.

Question 4 (CISM2-004)

Correct answer: D - The governing body and executive leadership

The governing body and executive leadership are ultimately accountable for enterprise direction and oversight, including information security governance. Assessors provide assurance, operations perform assigned activities, and vendors deliver products or services without assuming the enterprise's governance accountability.

Question 5 (CISM2-005)

Correct answer: D - Incompatible operational, approval, and assurance responsibilities undermine independent oversight.

Combining control operation, exception approval, and independent assessment creates a material conflict of interest and weakens assurance. Automation and record detail do not correct incompatible duties, while privileged access requires business-aligned governance rather than exclusive technology ownership.

Question 6 (CISM2-006)

Correct answer: B - Identify information risks and security requirements within the capability and architecture decisions.

Early participation allows security requirements and information risks to influence business processes, information flows, and later technology choices. Waiting forfeits design opportunities, the security manager does not own the entire enterprise capability, and automatically copying controls ignores the new service context.

Question 7 (CISM2-007)

Correct answer: C - To clarify who may make decisions, who is accountable, and when escalation is required

Defined decision rights establish authority, accountability, and escalation so governance actions are consistent and timely. Control operators cannot automatically accept business risk, collaboration remains essential, and different decisions may appropriately belong to different authorized roles or forums.

Question 8 (CISM2-008)

Correct answer: B - Document the exposure, assign risk ownership, approve time-bound treatment, and monitor integration milestones.

A time-bound, owned, and monitored treatment plan enables the business objective while keeping inherited exposure visible and governed. Indefinite acceptance lacks control, immediate replacement may create disproportionate disruption, and technical staff cannot assume accountability for enterprise business risk by default.

Question 9 (CISM2-009)

Correct answer: D - Designate an accountable process owner and document responsibilities, handoffs, and escalation criteria.

A single accountable process owner with documented responsibilities and handoffs resolves ambiguity across participating functions. Independent targets can perpetuate gaps, application support alone may not control the end-to-end process, and internal audit should assess rather than perform operational activities.

Question 10 (CISM2-010)

Correct answer: D - Assess security and business impacts, then submit the exception to architecture governance.

Architecture exceptions require an impact assessment and a decision by the authorized governance forum, which can weigh security, business value, and enterprise consequences. Automatic rejection ignores legitimate exceptions, budget ownership does not confer approval authority, and technical features alone omit information, process, and strategic impacts.

Question 11 (CISM2-011)

Correct answer: A - Enterprise objectives, risk appetite, obligations, threat conditions, and organizational capabilities

A sound strategy reflects enterprise direction, approved risk boundaries, obligations, the external threat environment, and internal capability. Technologies, historical issues, and staff preferences may provide inputs, but none of them alone captures the full strategic context.

Question 12 (CISM2-012)

Correct answer: C - That current detection practices cannot achieve the required notification outcome

The comparison shows that the current quarterly process cannot support the desired four-hour notification capability. It does not by itself mandate eliminating questionnaires or imposing identical monitoring, and strategic capability needs should be addressed proactively rather than only after an event.

Question 13 (CISM2-013)

Correct answer: C - Define measurable resilience objectives and initiatives consistent with the approved outage tolerance.

The approved tolerance should be translated into measurable resilience objectives, ownership, and initiatives that guide investment and performance. Operational ownership does not remove the strategic security concern, product counts do not express resilience, and waiting for an outage is inconsistent with proactive governance.

Question 14 (CISM2-014)

Correct answer: B - Define organizational needs, map complementary practices, and tailor an integrated approach.

The organization should begin with its needs, then combine and tailor complementary practices while addressing overlap. Requirement volume does not prove suitability, full duplicate adoption can waste resources, and unrelated local models would weaken enterprise consistency.

Question 15 (CISM2-015)

Correct answer: D - Preserve mandatory and high-value dependencies, consolidate duplication, and defer lower-priority enhancements.

Risk-based rebalancing preserves obligations and critical dependencies while removing duplication and deferring lower-value work. Equal reductions ignore differing priorities, sponsor seniority is not a sufficient criterion, and abandoning all multiyear work would undermine sustainable strategic capability.

Question 16 (CISM2-016)

Correct answer: A - Executive endorsement has not been converted into accountable ownership and resource commitments.

Visible endorsement is insufficient unless leaders establish accountable owners, commit resources, and resolve barriers. Technical metrics and additional projects do not create ownership, while a project management platform cannot substitute for leadership decisions and commitments.

Question 17 (CISM2-017)

Correct answer: C - Establish data ownership and classification before capabilities that depend on trustworthy data context.

Data ownership and classification are foundational dependencies for consistent access decisions and meaningful monitoring. Technical sophistication does not determine sequence, ignoring dependencies increases execution risk, and complete application replacement is not required before improving governance.

Question 18 (CISM2-018)

Correct answer: A - The percentage of critical violations resolved within the approved time threshold

The percentage of critical violations resolved within the target period measures the desired risk outcome. Document length, raw review volume, and meeting attendance measure activity or inputs without showing whether critical exposure is being reduced promptly.

Question 19 (CISM2-019)

Correct answer: D - Realign investments to transition risks and shared target capabilities while maintaining necessary interim protection.

The roadmap should support shared target capabilities while protecting material transition risks during migration. Continuing all investments can waste resources, abruptly stopping legacy controls creates exposure, and independent target designs conflict with the approved common-services architecture.

Question 20 (CISM2-020)

Correct answer: B - Develop a workforce plan combining training, targeted hiring, and appropriate external support.

A balanced workforce plan can close capability gaps within strategic timeframes through development, recruitment, and controlled sourcing. Ignoring gaps threatens delivery, limiting objectives to current skills undermines enterprise needs, and tools cannot replace governance expertise and accountability.

Question 21 (CISM2-021)

Correct answer: B - To establish management direction, principles, authority, and mandatory expectations

An enterprise policy communicates management direction, governing principles, authority, and mandatory expectations. Detailed steps belong in procedures, vulnerability lists are operational records, and policy guides rather than replaces supporting standards, procedures, and guidelines.

Question 22 (CISM2-022)

Correct answer: A - The access governance redesign because it addresses a strategic dependency and associated risk.

The access governance redesign directly enables the approved partner strategy and manages risk created by that dependency. Visibility and submission order do not establish enterprise value, and security strategy should enable properly governed business expansion rather than oppose it categorically.

Question 23 (CISM2-023)

Correct answer: C - Initiate a focused strategy review of changed stakeholders, dependencies, risks, and capabilities.

The franchise model materially changes strategic assumptions, so a focused review is warranted before the regular cycle. Waiting prolongs misalignment, imposing all internal controls ignores context, and franchise participation does not transfer ownership of the enterprise's security strategy.

Question 24 (CISM2-024)

Correct answer: B - Revisit benefits, cost allocation, accountabilities, and sponsorship with the affected decision-makers.

Stakeholder commitment depends on transparent benefits, equitable resource decisions, clear accountability, and active sponsorship. Immediate punitive escalation ignores a legitimate governance issue, cancellation may sacrifice strategic value, and automatically shifting all costs to security may further distort ownership and incentives.

Question 25 (CISM2-025)

Correct answer: C - Its initiatives do not address the governance capability needed to reach the desired state.

The desired state requires common criteria and decision processes, so technology purchases alone leave the central governance gap unresolved. Roadmaps may appropriately contain policy and technology initiatives, technology can support strategic outcomes, and the desired state must guide projects rather than follow them.

Question 26 (CISM2-026)

Correct answer: A - Risk exposure, expected outcomes, lifecycle costs, alternatives, dependencies, and transition impacts

Decision-makers need a balanced comparison of exposure, outcomes, lifecycle cost, alternatives, dependencies, and transition effects. Technical weaknesses alone omit business considerations, replacement is not exempt from cost evaluation, and purchase price alone excludes material implementation and operating factors.

Question 27 (CISM2-027)

Correct answer: A - Convene the authorized stakeholders to reconcile objectives, dependencies, risk boundaries, and investment priorities.

The conflicting roadmaps require joint, authorized governance to reconcile enterprise objectives, architecture dependencies, risk boundaries, and investments. Waiting allows misalignment to deepen, independent optimization can produce incompatible outcomes, and architecture direction does not replace the need for an aligned information security strategy.